

ISO 27001 Gap Analysis case study

Purpose:

The **purpose** of this case study is to show how a U.S. local authority evaluated its information security practices against the **ISO/IEC 27001 standard** (an international standard for information security management systems).

Scope :

The **scope** of the document *“USA Local Authority ISO27001 Gap Analysis Case Study”* is:

- **Target Organization** – A U.S. local authority (government body) that handles sensitive citizen and administrative information.
- **Assessment Area** – Evaluation of the authority’s existing **information security management system (ISMS)** against the requirements of the **ISO/IEC 27001 standard**.
- **Purpose of Scope** – To determine where the authority is already compliant, where gaps exist, and what actions are needed to achieve full compliance and certification.
- **Boundaries** – The case study does not describe the entire ISO 27001 implementation. Instead, it focuses only on the **gap analysis phase** (the first step before implementing or certifying an ISMS).
- **Output of Scope** – A structured gap analysis report highlighting compliance gaps, risks, and a recommended roadmap for ISO 27001 alignment.

Policy Objectives

1. **Protect Confidentiality** – Ensure information is only accessible to authorized users.
2. **Maintain Integrity** – Safeguard data against unauthorized alteration or destruction.
3. **Ensure Availability** – Keep information and systems available when required.
4. **Legal & Regulatory Compliance** – Meet all applicable laws, regulations, and contractual obligations.
5. **Risk Management** – Identify, assess, and treat information security risks effectively.
6. **Incident Response & Continuity** – Detect, respond, and recover from security incidents with minimal disruption.
7. **Awareness & Accountability** – Promote security awareness among staff and define clear responsibilities.
8. **Continuous Improvement** – Regularly monitor, review, and improve the ISMS to address evolving threats.

Procedure Followed

1. **Initial Scoping** – Defined which parts of the organization and systems would be covered by ISO 27001 (e.g., citizen data, IT infrastructure, services).
2. **Document Review** – Collected and reviewed existing security policies, procedures, and records.
3. **Interviews & Workshops** – Engaged with management and staff to understand current practices and controls.
4. **Gap Assessment** – Compared existing controls against the requirements of ISO 27001 Annex A and the standard's clauses.
5. **Risk Identification** – Highlighted where controls were missing, weak, or non-compliant.
6. **Findings Report** – Documented the gaps, strengths, and areas needing improvement.
7. **Recommendations & Roadmap** – Provided an action plan with prioritized steps to move towards ISO 27001 compliance and eventual certification

Extra Policies to Mitigate/Fulfill Gaps

1. **Information Security Policy (Master Policy)**
 - Clear commitment from management.
 - Defines security objectives and scope.
2. **Access Control Policy**
 - Role-based access, strong authentication, least privilege.
 - Covers user onboarding/offboarding and password management.
3. **Acceptable Use Policy (AUP)**
 - Rules for using organizational IT assets (email, internet, removable media).
 - Helps reduce insider threats.
4. **Data Protection & Privacy Policy**
 - Compliance with GDPR, HIPAA, or local data protection laws.
 - Covers handling, classification, and retention of personal data.
5. **Incident Response Policy**
 - Defines how to detect, report, and respond to security incidents.
 - Includes escalation paths and documentation requirements.
6. **Business Continuity & Disaster Recovery Policy**
 - Procedures for backup, recovery, and continuity during cyberattacks or natural disasters.
7. **Risk Management Policy**
 - Formal process for identifying, analyzing, and mitigating risks.
 - Regular risk assessments and treatment plans.
8. **Encryption & Cryptographic Policy**
 - Standards for data encryption (in transit and at rest).
 - Key management procedures.
9. **Third-Party / Supplier Security Policy**
 - Security requirements for vendors, contractors, and service providers.
 - Protects against supply-chain risks.
10. **Remote Work & Mobile Device Policy**
 - Secure use of laptops, smartphones, and remote access (VPN, MFA).
11. **Security Awareness & Training Policy**
 - Mandatory staff training on phishing, social engineering, and security responsibilities.
12. **Logging & Monitoring Policy**
 - Defines what activities are logged, how they are reviewed, and retention of logs.
13. **Patch Management & System Hardening Policy**

- Ensures timely updates and configuration baselines for servers, apps, and endpoints.